

Министерство образования Республики Беларусь

Учреждение образования
«БЕЛОРУССКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ
ИНФОРМАТИКИ И РАДИОЭЛЕКТРОНИКИ»

Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий

Лабораторная работа №4

по дисциплине «Проектирование защищенных интеллектуальных
информационных систем»

на тему «Безопасность работы серверов в сети Internet.

Часть 2. Усовершенствование системы безопасности удалённых серверов»

Выполнил студент гр. 321701

Ковальчук В. Н.
Самович В. М.

Проверил

Сальников Д. А.

Минск 2026

Цель: получить практические навыки установки, настройки и применения системы обнаружения/предотвращения вторжений (IDS/IPS) для защиты реального удалённого сервера, а также навыки сравнительного анализа сетевой активности до и после её внедрения.

Задание:

а) Установить и настроить программное обеспечение, позволяющее усовершенствовать защиту сервера, согласно варианту.

б) Выполнить анализ данных логов различных подсистем, в том числе SSH и веб-сервера удалённого сервера, за несколько дней.

в) Оформить отчёт о проделанной работе.

Постановка задачи. В качестве варианта выбран OSSEC – система обнаружения вторжений на основе хоста (HIDS) с возможностью активного ответа (то есть способная работать и как IPS). Она установлена на том же сервере (`test-lab4.work.gd`), что использовался в лабораторной работе №4.1, и настроена на мониторинг тех же подсистем – SSH и веб-сервера Caddy, – чтобы можно было напрямую сравнить сетевую активность и её обработку до появления OSSEC (данные лабораторной работы №4.1) и после включения его активного ответа.

Описание установленного программного обеспечения

OSSEC – система обнаружения вторжений на основе хоста (HIDS), устанавливаемая непосредственно на защищаемый сервер, а не работающая на отдельном сетевом сенсоре (в отличие, например, от Snort или Suricata). Задачи, которые она решает:

- **Анализ журналов (log analysis)** – построчное чтение указанных лог-файлов, разбор записи декодерами (для распознанных форматов, включая формат `sshd`) и сопоставление с базой правил обнаружения; при совпадении формируется тревога с уровнем критичности.

- **Контроль целостности файлов (syscheck/FIM)** – периодическая проверка контрольных сумм важных файлов системы на предмет несанкционированного изменения.

- **Обнаружение руткитов (rootcheck)** – проверка признаков скомпрометированной системы (аномальные записи в системных структурах, известные сигнатуры).

- **Активный ответ (active response)** – при тревоге выше заданного порога критичности автоматически выполняется команда реагирования: в данном случае `firewall-drop` (добавление правила `iptables DROP` для IP-источника) и `host-deny` (запись в `/etc/hosts.deny`), на 600 секунд. Именно эта возможность превращает систему из чисто наблюдающей (IDS) в способную самостоятельно вмешиваться (IPS).

Принцип работы. OSSEC установлен в режиме `local` (сервер и агент совмещены на одной машине, что уместно для единственного защищаемого хоста) из исходного кода (готового пакета для Ubuntu 24.04 нет). Отдельные процессы-демоны выполняют разные роли: `ossec-logcollector` читает указанные файлы и передаёт новые строки `ossec-analysisd`, который применяет декодеры и правила; при срабатывании правила уровня 6 и выше `ossec-execd` запускает соответствующий скрипт активного ответа. Отдельно настроен список исключений (`allow_list`) – IP-адреса и подсети, которые не блокируются активным ответом ни при каких обстоятельствах (публичный адрес самого сервера и внутренняя подсеть, через которую администратор подключается по VPN) – без этого существует риск, что система заблокирует легитимный, но интенсивный доступ, включая доступ самого администратора.

Анализируемые подсистемы и файлы

Анализируемые подсистемы – те же, что и в лабораторной работе №4.1: служба SSH (`sshd`) и веб-сервер `Caddy`, – с добавлением самого OSSEC как третьей подсистемы, чьи собственные журналы теперь тоже являются предметом анализа.

- `/var/log/auth.log` и `/var/log/caddy/access.log` – те же файлы, что описаны в отчёте по лабораторной работе №4.1; теперь они читаются не только вручную, но и потоково самим OSSEC.

- `/var/ossec/logs/alerts/alerts.log` – журнал всех тревог OSSEC с указанием сработавшего правила, его уровня критичности, исходного события и, если оно было определено, IP-адреса источника.

- `/var/ossec/logs/active-responses.log` – журнал именно исполненных действий активного ответа: какой IP, когда и на какой срок был заблокирован. Это основной источник данных для демонстрации перехода от обнаружения к предотвращению.

Анализ запросов из сети Internet до и после настройки

Раздел будет заполнен после нескольких дней работы сервера с включённым OSSEC. Данные лабораторной работы №4.1 (период без активного ответа) послужат базовым уровнем «до»; здесь будет приведено прямое сравнение с периодом «после»: изменение числа успешных подключений с уже заблокированных источников, число и состав реальных срабатываний активного ответа (`active-responses.log`), а также то, повлияла ли работа OSSEC на журнал веб-сервера (учитывая, что активный ответ в текущей конфигурации настроен по правилам, специфичным для SSH, а не для HTTP-трафика).

Сравнение с аналогами

Система	Тип	Источник данных	Особенность
OSSEC	HIDS (+active response)	Логи файлов на хосте	Лёгкая установка на один сервер, встроенный IPS-режим через скрипты
Snort	NIDS/NIPS	Сетевые пакеты (libpcap)	Классический сигнатурный анализ трафика, требует описания правил под протокол
Suricata	NIDS/NIPS	Сетевые пакеты, многопоточность	Совместим с правилами Snort, дополнительно разбирает прикладные протоколы (HTTP, TLS и т. д.)
Tripwire	HIDS (только FIM)	Контрольные суммы файлов	Узкоспециализирован на контроле целостности, не анализирует сетевой трафик и логи в реальном времени
Zeek (Bro)	NIDS (анализ, не блокировка)	Сетевые пакеты	Ориентирован на подробное протоколирование и последующий анализ, а не на немедленную блокировку

Таблица 1 – OSSEC и альтернативные варианты задания

Для единственного сервера с ограниченным набором подсистем (SSH и один веб-сервер) выбор HIDS-решения, читающего уже существующие логи, вместо NIDS-решения, анализирующего сырой сетевой трафик, обоснован меньшими требованиями к настройке (не нужно описывать сигнатуры для протоколов) и меньшей нагрузкой на единственный процессор сервера.

Демонстрация работы установленного программного обеспечения

Раздел будет дополнен снимками экрана/выдержками из `active-responses.log` после того, как накопится статистика реальных срабатываний.

Выводы

Раздел будет окончательно сформулирован после анализа данных из раздела «Анализ запросов из сети Internet до и после настройки» – ниже приведён каркас выводов, который будет дополнен конкретными числами и наблюдениями.

Семантически лабораторная работа должна показать разницу между обнаружением и предотвращением: сам факт журналирования (лабораторная работа №4.1) позволяет знать о происходящем, но никак на него не влияет, тогда как активный ответ OSSEC превращает пассивное знание в действие – источник, уже опознанный как вредоносный, перестаёт получать саму возможность продолжить попытки. *[после сбора данных: подтвердить конкретными числами – сколько уникальных источников было заблокировано за период наблюдения, сократилось ли количество последующих попыток с тех же подсетей]*

С прагматической точки зрения работа должна продемонстрировать, что внедрение IDS/IPS даже в простейшей, однохостовой конфигурации (отдельный сетевой сенсор не требуется) ощутимо меняет то, с какими данными сервер сталкивается в дальнейшем – активный ответ не только защищает, но и сам становится источником полезных данных (`active-responses.log`), которых не существовало до его установки. *[после сбора данных: указать, оправдал ли себя выбор именно HIDS-решения по сравнению с сетевыми альтернативами из варианта задания, и с какими ограничениями пришлось столкнуться на практике]*